Central de Confiança

Nossa postura de segurança e compromisso com a conformidade

Status de Conformidade

- Compatível com o RGPD — Privacidade de dados
- SOC 2 Tipo II — Meta 3º trim. de 2027
- Certificado no Azure — Infraestrutura
- ISO 27001 — Planejado para 2028

Criptografia

Em Trânsito: Todos os dados em trânsito são criptografados usando TLS 1.2 ou superior. Conexões HTTP são redirecionadas automaticamente para HTTPS.

Em Repouso: Registros do banco de dados e backups são criptografados com AES-256. As chaves de criptografia são gerenciadas separadamente usando o Azure Key Vault.

Controle de Acesso

- Autenticação: autenticação multifator (MFA) via Microsoft Entra ID (Azure AD)
- Autorização: controle de acesso baseado em funções (RBAC) aplicado nas camadas de aplicação e banco de dados
- SSO: logon único SAML 2.0 disponível para clientes Enterprise via WorkOS
- Gerenciamento de sessão: as sessões expiram após 24 horas de inatividade; reautenticação forçada para operações sensíveis

Infraestrutura e Disponibilidade

- Provedor de nuvem principal: Microsoft Azure (certificado para HIPAA, FedRAMP, SOC 2)
- Região física ativa: implantação única em Azure West US 2
- Banco de dados: MySQL gerenciado no Azure com backups automáticos
- Cache: Azure Managed Redis (Balanced_B3) com alta disponibilidade habilitada e acesso privado
- Perímetro: Cloudflare como CDN/WAF na frente da origem no Azure
- Recuperação de desastres: backups geo-redundantes; RTO < 4 horas, RPO < 1 hora
- SLA: 99,9% de disponibilidade garantida para planos pagos (exclui manutenção programada)

Auditoria e Monitoramento

- Registros de auditoria: todas as ações do usuário, chamadas de API e acessos a dados são registrados e retidos por 7 anos
- Monitoramento: monitoramento de segurança em tempo real usando o Azure Security Center; alertas para atividades suspeitas
- Detecção de intrusão: detecção e prevenção de intrusão de rede habilitada em todos os endpoints

Subprocessadores

Trabalhamos com provedores líderes do setor para serviços específicos:

Processador	Finalidade	Localização
Microsoft Azure	Computação, Armazenamento, Rede, Inferência de IA (Azure OpenAI)	Azure West US 2
Paddle	Processamento de Pagamentos	US/UK
WorkOS	Autenticação e SSO	US
Google Gemini AI	Serviços de LLM Opcionais	US

Resposta a Incidentes

- Tempo de resposta: incidentes de segurança são investigados dentro de 2 horas após a detecção
- Notificação: clientes afetados são notificados dentro de 72 horas após a confirmação de uma violação de dados (conforme Art. 33-34 do RGPD)